

Proyecto de Investigación - IC-8071

Seguridad del Software

Escuela de Computación
Carrera de Ingeniería en Computación. Plan 412.
Prof. Natán Fernández de Castro
Abril, 2026

Objetivo: Motivar la investigación aplicada sobre vulnerabilidades de seguridad documentadas en bases de datos públicas (CVE/NVD), a través de la elaboración de un paper en formato IEEE que cubra el análisis teórico, la replicación práctica en un entorno controlado y la propuesta de remediación de una vulnerabilidad alineada con los contenidos del curso, vinculando los conceptos de CWE, CAPEC y CVSS.

1. Datos generales

Fecha de entrega y presentación:	Miércoles 27 de mayo de 2026 antes de las 13:59:59 GMT-6
Lenguaje:	N/A
Recurso humano:	Grupos de 2 a 3 estudiantes
Valor de la asignación:	10%

2. Descripción general

El estudio de los patrones de ataque, vectores de explotación y estrategias de defensa desde una perspectiva abarca tanto la teoría como la práctica. Sin embargo, el ciclo completo de comprensión de una vulnerabilidad (desde su descubrimiento y catalogación pública hasta su replicación controlada y remediación) es una competencia que solo se consolida cuando el estudiante la ejecuta de principio a fin en un escenario real.

Para este proyecto de investigación cada grupo seleccionará una vulnerabilidad documentada en bases de datos públicas como el *National Vulnerability Database* (NVD) del NIST o los boletines de CISA, y realizará un ciclo completo de cuatro fases: *evaluar, investigar, replicar y remediar*.

En la primera fase, el grupo realizará un análisis de severidad calculando de forma independiente el puntaje CVSS de la vulnerabilidad y comparándolo con el puntaje oficial, lo que permitirá comprender de primera mano cómo funciona el framework de puntuación y sus limitaciones.

En la segunda fase, el grupo investigará el contexto técnico de la vulnerabilidad, su clasificación en los ecosistemas de CWE (debilidad raíz), CAPEC (patrón de ataque asociado) y CVE (instancia específica).

En la tercera fase, el grupo montará un entorno controlado en una máquina virtual para replicar la vulnerabilidad de forma segura y documentar el proceso de explotación paso a paso.

En la cuarta fase, el grupo propondrá e implementará una remediación que mitigue la vulnerabilidad en el mismo entorno, verificando que la explotación ya no sea posible tras aplicar la corrección.

El entregable escrito deberá presentarse en formato IEEE (IEEEtran) utilizando LaTeX, y los resultados se expondrán en una presentación oral con demostración en vivo de la replicación y remediación de la vulnerabilidad.

3. Requerimientos funcionales

Requerimientos

- **Selección de vulnerabilidad:** Cada grupo deberá seleccionar una vulnerabilidad de las bases de datos públicas CVE (<https://www.cve.org>), NVD del NIST (<https://nvd.nist.gov>) o los boletines de CISA (<https://www.cisa.gov/news-events/bulletins>). La selección está sujeta a las siguientes restricciones:
 - La vulnerabilidad debe tener un CVSS Base Score ≥ 7.0 (clasificación High o Critical según la escala CVSS v3.1 o v4.0), lo cual garantiza que el grupo trabaje con una vulnerabilidad de complejidad técnica significativa.
 - La vulnerabilidad debe estar alineada con al menos uno de los siguientes contenidos del programa del curso:
 - Explotación de software de servidores (escalación de privilegios, puntos de inyección, explotación de la confianza).
 - Explotación de software en clientes (XSS, client scripts, código malicioso).

- Alteración de entrada de usuario (detección de intrusos, solicitudes equivalentes, audit poisoning).
 - Buffer overflow (stack overflow, heap overflow, payloads).
- Dos grupos no podrán investigar la misma vulnerabilidad (mismo CVE ID). La selección se coordinará por orden de llegada en un documento compartido habilitado por el profesor, donde cada grupo deberá registrar el CVE ID, el CVSS Base Score, la categoría (contenido) del curso con la que se relaciona y una breve justificación de la elección.
- **Reserva de vulnerabilidades:**
https://docs.google.com/spreadsheets/d/1NJsVBa49xuxNt4UZ4uxyA5U5k_m_cm5zaPkDVqzki1c/edit?usp=sharing
- **Entorno de replicación:** Cada grupo deberá montar su propio entorno controlado utilizando máquinas virtuales (VirtualBox, VMware o similar).
 - El entorno debe incluir como mínimo una **máquina** que reproduzca la configuración **vulnerable** (sistema operativo, versión de software, servicio afectado) y, si aplica, una máquina **atacante**.
 - Se recomienda utilizar distribuciones como Kali Linux para las herramientas **ofensivas** y la versión específica del software vulnerable para la **máquina objetivo**.
 - **Bajo ninguna circunstancia se debe replicar la vulnerabilidad en entornos de producción, redes institucionales o sistemas de terceros.**

Requerimientos técnicos

El proyecto se divide en cuatro fases secuenciales. Cada fase alimenta la siguiente, por lo que se recomienda seguir el orden establecido.

Fase 1. Evaluación de severidad (CVSS):

- Antes de profundizar en la investigación técnica, el grupo deberá realizar un ejercicio de evaluación de severidad que

permita comprender de primera mano cómo funciona el framework CVSS.

- El grupo deberá leer la descripción de la vulnerabilidad en NVD y en la documentación del proveedor, y luego calcular de forma independiente el puntaje CVSS utilizando la calculadora oficial de FIRST (<https://www.first.org/cvss/calculator/4.0>), evaluando cada métrica base sin consultar previamente el vector string oficial publicado en NVD.
- Una vez obtenido el puntaje propio, el grupo deberá comparar su vector string con el oficial, identificando métrica por métrica en cuáles coincidieron y en cuáles difirieron, y elaborar un análisis razonado de las diferencias, considerando tanto las diferencias inherentes entre versiones del framework (los puntajes publicados en NVD suelen usar CVSS v3.1, mientras que la calculadora de FIRST trabaja con v4.0) como las diferencias de interpretación subjetiva del grupo frente al evaluador oficial.
- Este ejercicio deberá incluir una reflexión sobre la objetividad del CVSS como sistema de puntuación y sus implicaciones para la gestión de vulnerabilidades en una organización.

Fase 2. Investigación:

- El grupo deberá investigar y documentar el contexto completo de la vulnerabilidad seleccionada, cubriendo los siguientes aspectos:
 - Descripción técnica de la vulnerabilidad y del software/servicio afectado
 - Identificación de la debilidad raíz en la taxonomía CWE.
 - Explicación de por qué esa debilidad permite la vulnerabilidad.
 - Identificación del patrón de ataque asociado en CAPEC.
 - Descripción del vector de ataque.
 - Investigación del contexto histórico de la vulnerabilidad: cuándo fue descubierta, si fue explotada activamente (in the wild), qué impacto tuvo y qué parches o actualizaciones se publicaron.

Fase 3. Replicación:

- El grupo deberá replicar la explotación de la vulnerabilidad en su entorno controlado, documentando:
 - La configuración completa del entorno de laboratorio (sistema operativo, versiones exactas del software vulnerable, topología de red entre las máquinas virtuales)
 - Las herramientas utilizadas para la explotación y justificación de su elección
 - El proceso de explotación paso a paso con capturas de pantalla
 - Explicación de cada comando o acción,
 - Evidencia clara de que la explotación fue exitosa (por ejemplo, acceso no autorizado obtenido, datos extraídos, servicio comprometido, etc.).

Fase 4. Remediación:

- El grupo deberá proponer e implementar una remediación para la vulnerabilidad explotada. Esta fase tiene dos componentes:
 - **(1) Propuesta teórica:** El grupo describirá las estrategias de mitigación recomendadas por la comunidad de seguridad (parches oficiales, configuraciones, buenas prácticas de codificación, etc.), vinculándolas con los principios de Security by Design.
 - **(2) Verificación práctica:** El grupo aplicará la remediación en el mismo entorno de laboratorio y demostrará que la explotación ejecutada en la Fase 3 ya no es posible tras la corrección, documentando el antes y el después con capturas de pantalla comparativas.
- **Estructura del paper (formato IEEEtran en LaTeX):**
 1. **Abstract:** Resumen del trabajo realizado en no más de 250 palabras.
 2. **Introducción:** Contextualización del problema de seguridad que aborda la vulnerabilidad seleccionada.
 3. **Marco teórico:** Desarrollo de los conceptos teóricos necesarios para comprender la vulnerabilidad investigada
 4. **Evaluación de severidad (CVSS):** Documentación completa de la Fase 1.

5. **Análisis de la vulnerabilidad:** Documentación detallada de la Fase 2.
6. **Entorno de laboratorio:** Descripción completa del entorno montado para la replicación. (Topología, versiones, configuración de red, servicios).
7. **Replicación de la vulnerabilidad:** Documentación detallada de la Fase 3.
8. **Remediación:** Documentación detallada de la Fase 4.
9. **Discusión:** Reflexión sobre el trabajo realizado.
10. **Conclusiones:** Resumen de los hallazgos principales del trabajo, verificación del cumplimiento de los objetivos planteados en la Introducción, y recomendaciones finales para organizaciones que pudieran estar expuestas a esta vulnerabilidad.
11. **Referencias:** Todas las fuentes consultadas deben citarse siguiendo el estilo de citación IEEE (numérico entre corchetes). Mínimo 10 referencias.

- **Estructura sugerida de la presentación oral (19 minutos):**

1. Introducción y contexto.
2. Análisis de severidad y marco teórico.
3. Entorno de laboratorio.
4. Demostración en vivo de la replicación.
5. Demostración en vivo de la remediación.
6. Conclusiones y lecciones aprendidas.
7. Preguntas.
 - Nota: Se recomienda que el grupo tenga preparado un video de respaldo de las demostraciones en vivo (Secciones 4 y 5) en caso de que ocurra algún problema técnico durante la presentación. Si la demostración en vivo falla y no existe video de respaldo, la sección de demostración se calificará con 0.

Aspectos Administrativos

4. Entregables

Escuela de Computación – Técnico en Desarrollo de aplicaciones de Software

- Requerimientos especificados en la sección 3 de este documento y comprimidos dentro de un archivo .zip:
 - Paper en formato PDF.
 - Archivos fuente de LaTeX (.tex, imágenes, bibliografía .bib).
 - Diapositivas para presentación.
 - Video(s) de respaldo de la demostración (opcional).

5. Evaluación

Resultado de aprendizaje y estrategia metodológica	Porcentaje
Evaluación de severidad	10%
Investigación	15%
Replicación	15%
Remediación	10%
Calidad del paper	25%
Demostración en vivo	25%
Total	100%

6. Aspectos Adicionales

Consultar recursos externos (blogs, videos, foros) es permitido y esperable, así es como funciona la industria real. Sin embargo, el estudiante debe referenciar todo recurso consultado en la sección de Referencias del paper y ser capaz de explicar con sus propias palabras los recursos referenciados.

Se aplican las siguientes restricciones:

1. Si no se entrega lo solicitado, automáticamente se obtiene una nota de 0.
2. La asignación debe ser desarrollada en el ambiente especificado al inicio del enunciado, en caso contrario se obtendrá una nota de 0.

3. Si no se siguen las reglas del formato del envío a través de Google Classroom se obtendrá una nota de 0.
4. La revisión del entregable será realizada por parte del profesor o el asistente del curso.
5. Cada grupo tendrá como máximo 19 minutos para exponer su trabajo al profesor y realizar la defensa de éste, es responsabilidad de los estudiantes mostrar todo el trabajo realizado, por lo cual se recomienda tener todo listo antes de iniciar la defensa.
6. Cada grupo es responsable de llevar los equipos requeridos para la revisión, si no cuentan con estos deberá avisar al menos 2 días antes de la revisión al profesor para buscar una alternativa.
7. Durante la revisión podrán participar asistentes, otros profesores y el coordinador del programa.
8. Es responsabilidad de los estudiantes mostrar todo el trabajo realizado, por lo cual se recomienda asegurarse de enviar todo lo que se solicitó en este documento.
9. Cualquier indicio de copia será calificado con una nota de 0 y será procesado de acuerdo con el reglamento.
10. Se asignará una penalización de 5 puntos sobre la nota total de la asignación por cada 15 minutos que el trabajo sea enviado después de la hora de entrega especificada en este documento. Excepto que exista un acuerdo con el Profesor de extensión de la hora y fecha de entrega.
12. La vulnerabilidad seleccionada debe ser única por grupo y reservada por medio del documento provisto por el profesor para reservación. Si dos grupos tienen la misma vulnerabilidad reservada a la hora de entrega, se les calificará a ambos con una nota de 0.
13. Bajo ninguna circunstancia se permite la replicación de vulnerabilidades fuera del entorno controlado de laboratorio del grupo.
14. Cualquier uso indebido de las técnicas aprendidas fuera del contexto académico constituye una violación ética y legal, y será procesado de acuerdo con el reglamento institucional y la legislación costarricense vigente

Profesor

Natán Fernández de Castro

Correo 1: natfernandez@itcr.ac.cr

Correo 2: nfernandez@fundatec.ac.cr